# 共识护航 AI Banking Agent 技术文档

> 2026 深圳国际金融科技大赛 · 国内人工智能赛道 · 银行 AI 智能体 项目名称：共识护航（一起算账 · 各自授权 · 证据核验） 文档版本：v1.0 | 日期：2026-10-20

---

## 1. 项目定位与六场景闭环

### 1.1 一句话定位

「共识护航」是一个面向**合租 / 家庭月末共同开销结算**的银行 AI 智能体：用**可核对的版本化约定**处理共同开销，用**证据卡**核验异常，用**独立授权**保护每个人的账户。

主场景自然语言需求：

> “帮我们结算本月共同开销，电费按入住天数分，停掉不用的共同会员。妈妈说有一笔陌生扣费，先核实。每个人留够下月开销，再分别安排自己的余钱。”

### 1.2 三个核心机制

| 机制 | 含义 | 落点 |
| --- | --- | --- |
| 有版本的共识账本 | 记录费用项目、参与者、分摊方式、权重、有效期、版本及成员确认；规则变更影响后续付款与授权 | `app/services/ledger.py` |
| 证据卡驱动异常核验 | 关联交易号、商户别名、订阅授权、时间、用户反馈；证据不足保持「待核验」 | `app/services/evidence.py`、`bill.py` |
| 共同看进度、个人管资金 | 共享空间仅展示经同意共享的结算状态；余额、完整流水、风险问卷、持仓留在本人私有空间 | `app/security/policy.py`、服务层对象级过滤 |

### 1.3 六场景闭环

| 方向 | 输入 | 业务工具 | 状态变化 / 回执 |
| --- | --- | --- | --- |
| 智能转账 | 姓名/手机号/备注 | `transfer` | 收款人唯一标识、即时/定时、AA 草稿、业务单号、部分完成 |
| 账单分析 | 导入/流水 | `bill_analysis` / `bill_report` | 分类统计、去重、个人/共同区分、异常候选 |
| 理财操作 | 问卷/申购/赎回 | `wealth_subscribe` / `wealth_redeem` | 持仓、订单、适配校验；赎回申请≠到账 |
| 卡片管理 | 申请/调整/挂失 | `virtual_card_apply` / `card_*` | 申请进度、限额、限制/解锁、挂失/解挂 |
| 订阅/代扣 | 流水识别/取消 | `subscribe_query` / `subscribe_cancel` | 授权回读、续费提醒、取消生效状态 |

| 方向 | 输入 | 业务工具 | 状态变化 / 回执 |
| --- | --- | --- | --- |
| 跨场景联动 | 复合需求 | DAG 调度 | 有依赖任务链 + 异常支线 |

**跨场景主链**：核验共同账单 → 形成并确认分摊规则 → 个人资金预留/必要赎回 → 到账后本人付款 → 回执对账。 **异常支线**：异常扣费 → 证据核验 → 本人选择订阅或卡片处置。

> 官网生日预订场景属于参考示例；本项目采用方案二的结算联动场景，不把参考示例当作官方必做项。

---

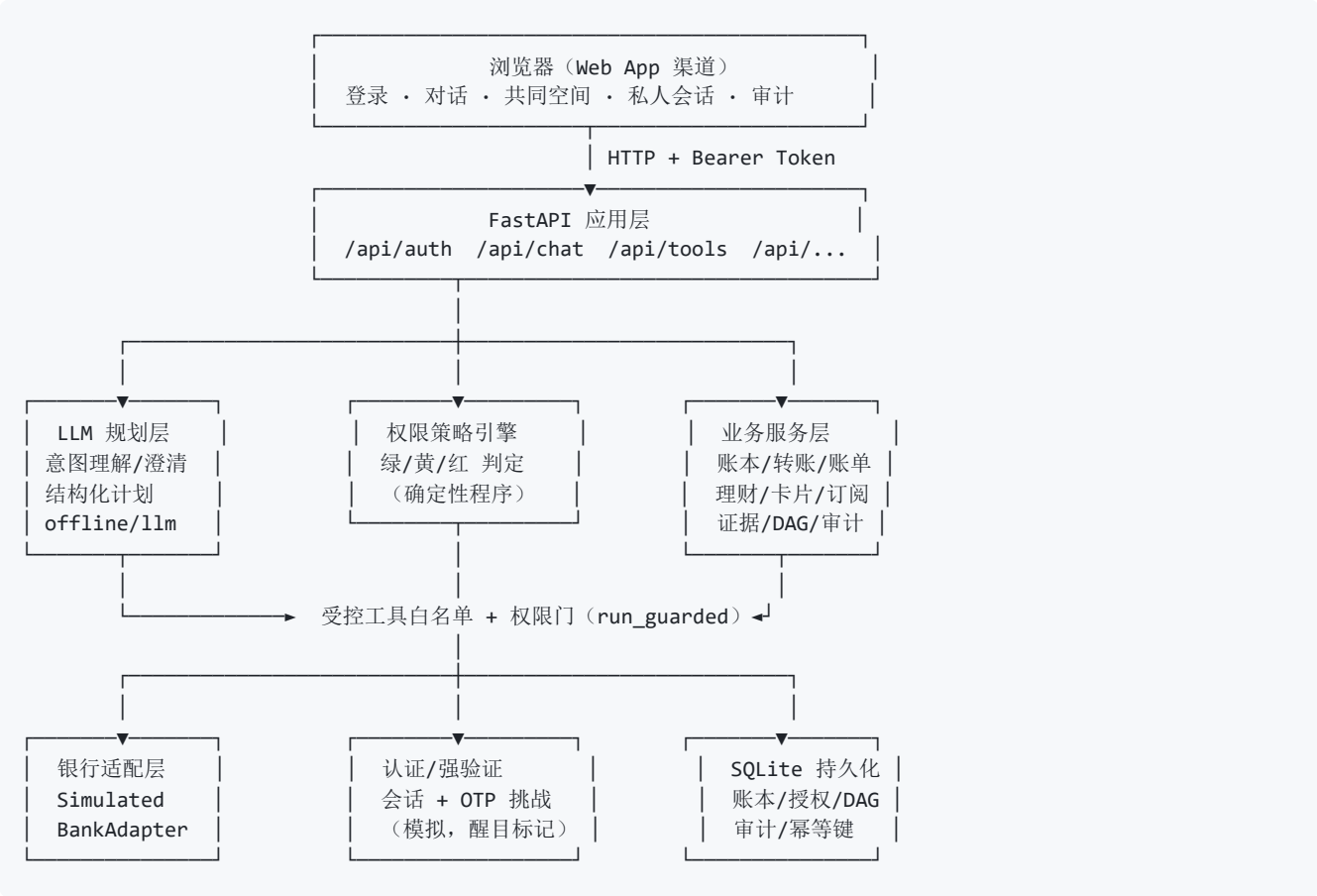
## 2. 需求追踪矩阵（摘要）

完整矩阵见仓库根目录 `requirements_matrix.md`。下表为核心条目与实现对应：

| 编号 | 要求 | 实现模块 | 测试 |
| --- | --- | --- | --- |
| O-03 | 覆盖全部六方向 | `app/services/` | test_transfer/test_bill/test_wealth/test_card/test_subscription/test_dag |
| O-04/08/09/10 | 绿/黄/红权限分级 | `app/security/policy.py` | test_permissions |
| O-06/07 | 意图理解 + DAG + 中断/回退/接管 | `app/llm/`、`app/services/dag.py` | test_dag/test_offline |
| P-01/02 | 版本化共识账本 + 规则变更 | `app/services/ledger.py` | test_ledger |
| P-03 | 证据卡核验 | `app/services/evidence.py` | test_evidence |

| 编号 | 要求 | 实现模块 | 测试 |
| --- | --- | --- | --- |
| P-04 | 共同/私有隔离 | 服务层对象级过滤 | test_isolation |
| P-07~P-14 | 验收案例 | 各服务 | test_ledger/test_dag/test_transfer/test_subscription |

## 3. 系统架构




**分层职责**：模型只负责理解、澄清、生成结构化计划与解释；金额计算、权限校验、业务执行、账本修改由确定性程序负责。身份来自服务端会话。

## 4. 数据与权限边界

| 数据 | 共享空间可见 | 本人私有空间可见 | 他人 |
| --- | --- | --- | --- |
| 费用项目 / 分摊规则 / 应付 / 已付 / 争议状态 | ✅ | ✅ | ❌（非成员） |
| 账户余额 | ❌ | ✅ | ❌ |

| 数据 | 共享空间可见 | 本人私有空间可见 | 他人 |
| --- | --- | --- | --- |
| 完整交易流水 | ❌ | ✅ | ❌ |
| 风险问卷 / 持仓 / 理财订单 | ❌ | ✅ | ❌ |
| 完整卡号 | ❌ | ✅ | ❌（共享仅掩码） |
| 证据卡 | ❌ | ✅ | ❌ |
| 强验证验证码 | ❌ | ❌ | ❌（不入审计/日志） |

**隔离实现**：所有查询接口以服务端会话身份（`current_user`）过滤，不存在按 user_id 查询任意账户的端点；转账/卡片/订阅操作均校验资源归属（对象级权限）；共享视图接口只返回结算字段。

---

## 5. 权限分级与授权绑定

### 5.1 权限策略引擎（确定性）

| 等级 | 动作 | 执行前要求 |
| --- | --- | --- |
| 绿色 | 余额/交易记录/账单分析/理财收益/持仓/产品/风险问卷/本人卡片/共享进度 | 自动执行 |
| 黄色 | 转账(日累计≤1000元)、订阅查询/取消、虚拟卡申请、AA 收款、证据反馈、提出/确认分摊规则 | 展示详情 + 明确确认 |
| 红色 | 转账(日累计>1000元)、密码修改、挂失/解挂、理财申购 | 强验证 |
| 红色(团队策略) | 赎回、额度调整、交易限制/解锁 | 强验证 |

> 赎回、额度调整、交易限制/解锁官网未逐项明确权限等级，本项目**保守按红色处理，并标注为团队策略**，不冒充官方要求。

### 5.2 关键规则

- 金额统一**整数分**；执行日按 Asia/Shanghai。
- 执行前**原子校验**日累计、并发占用、余额、有效预留、授权有效性。
- 日累计 1000 元：先转 800 元再转 300 元 → 第二笔日累计 1100 元 → 升级红色。
- 不能通过拆单、并发或跨会话绕过限额（占用计入当日累计）。
- 授权绑定：本人身份 + 动作 + 金额 + 收款人/目标资源 + 计划版本 + 规则版本 + 有效期 + 唯一操作标识。
- 改变关键参数 → 旧授权失效（revoked）；定时任务执行时重新校验；授权过期或风险升级转为等待本人验证。

---

## 6. DAG 与状态机

### 6.1 节点状态机

```
pending ──► running ──► success
   │           │
   │           ├──► waiting_confirm ──(确认)──► running
   │           ├──► waiting_auth    ──(验证)──► running
   │           └──► failed / unknown
   │
   ├──► frozen（规则变更冻结，可解冻重规划）
   ├──► skipped（依赖失败）
   └──► cancelled（未执行才可取消）
```

### 6.2 计划状态机

```
running ──► waiting（存在确认/验证项）──► running ──► completed
   │           │
   ├──► paused ──► running
   ├──► failed / cancelled
   └──► superseded（改口后新计划）
```

**约束**：前一步真实状态约束后一步（依赖失败则后序 skipped）；已执行交易只能生成补付/退款等补偿，不能删除流水伪装回滚。

---

## 7. 核心算法

### 7.1 最大余数法分摊（尾差守恒）

```
quota_i = total * weight_i / Σweight
floor_i = ⌊quota_i⌋
remain  = total - Σfloor_i          # 尾差（0 ≤ remain < 人数）
按「小数余数」降序，前 remain 人各 +1 分
```

保证 `Σamount_i == total`（以分为单位守恒）。验收案例：电费 240 元按 30/20/10 → 12000/8000/4000 分；宽带 90 元均分 → 3000/3000/3000 分；合计 150/110/70 元。

### 7.2 规则变更传播（P-08）

```
改分摊规则 →
  ① 旧版本 superseded；旧授权 revoked
  ② 冻结受影响的未付款任务（frozen）
  ③ 生成新版本（version+1）
  ④ 按「新分摊 - 已付款」生成补付/退款草稿
  ⑤ 已付款记录保留，未受影响任务继续
```

### 7.3 日累计判定

```
当日已成功+执行中转账总额 already
total = already + 本次金额
total > 100000 分 → 红色；否则 → 黄色
```

### 7.4 超时恢复（P-12）

转账请求超时 → 登记系统侧 `unknown`、银行侧 `success` → 回读原交易（`business_no`）→ 银行侧成功则补回执，不重复付款（幂等键兜底）。

---

## 8. 数据模型与接口契约

### 8.1 核心实体

用户/账户、共同空间/成员、联系人（收款人检索）、费用项目/规则版本/成员确认、付款任务、授权、证据卡、交易流水、卡片、订阅、理财产品/风险问卷/持仓/订单、DAG 计划/节点、会话、认证挑战、审计日志、安全锁。

### 8.2 接口契约（摘要）

| 方法 | 路径 | 说明 |
|---|---|---|
| POST | /api/auth/login | 登录，返回会话 token |
| GET | /api/me | 当前用户 + 余额 + 空间（本人范围） |
| POST | /api/chat | 自然语言 → 计划 → DAG 执行/澄清 |
| POST | /api/plans/{id}/continue | 确认/强验证后继续节点 |
| POST | /api/plans/{id}/pause | 暂停 |
| POST | /api/plans/{id}/resume | 恢复 |
| POST | /api/plans/{id}/cancel | 取消 |
| POST | /api/plans/{id}/nodes/{k}/modify | 改口（旧授权失效） |
| POST | /api/tools/run | 受控工具调用（经权限门） |
| GET | /api/space/{id}/progress | 共享结算进度 |
| GET | /api/audit | 本人脱敏审计 |

**通用返回契约**：每次操作携带身份、目标、参数、计划版本、唯一请求标识；返回 `待处理/成功/失败/未知` + 业务单号；查询接口回读状态，拒绝只生成“成功文案”。完整 API 见 `docs/API文档.md`。

---

## 9. 安全设计

| 措施 | 实现 |
|---|---|
| 独立权限校验 | `app/security/policy.py`（确定性，模型/前端/用户文本不可降级） |
| 防编造账户/交易结果 | 账户信息、交易结果、回执仅来自授权工具回读 |
| 防提示注入 | 商户备注/账单描述/检索结果作为不可信数据，不解析为指令 |

| 措施 | 实现 |
| --- | --- |
| 对象级权限 | 服务层按身份过滤，同步隔离数据库查询、上下文、日志、导出 |
| 完整审计 | 身份/意图摘要/计划版本/决策理由/证据引用/工具参数/授权引用/认证结果/业务回执/前后状态/时间（不记录验证码、密钥、思维链） |
| 连续失败熔断 | 阈值团队配置（默认 5 次/300 秒窗口），记录恢复条件 |
| 受限运行环境 | 默认不开放任意代码执行 |
| 人工接管 | 接管者仍受本人授权与角色权限约束，无万能管理员 |

---

## 10. 认证实现（强验证）

服务端认证挑战（模拟短信 OTP）实现：**过期**（默认 300 秒）、**一次性消费**、**防重放**（consumed 标记）、**限次**（默认 5 次）、**结果校验**（服务端哈希比对）、**绑定用户与操作**（operation_id 匹配）。

> ⚠️ **模拟认证说明**：本项目的强验证为**模拟实现**（醒目标记 `simulated=true`），不等价于正式的人脸/短信/U 盾强验证。模拟资金环境与认证强度是两个独立问题。**正式认证及主办方是否接受该方案列为待确认事项，不宣称完全达标。**

---

## 11. 故障恢复

- 幂等键：每个业务操作唯一幂等键；超时先按原操作标识查询，不盲目重试。
- 未执行任务可取消/重规划；已执行交易按业务规则生成补付/退款/补偿。
- DAG 有状态、持久化，重启后不丢失待处理任务。
- 转账超时 → 回读银行侧状态恢复回执。
- 连续失败 → 熔断锁定 + 记录恢复条件。

---

## 12. 真实测试结果

测试命令：`python -m pytest tests/ -q`（离线测试模式）。

**结果：129 条全部通过**（截至 2026-10-20）。覆盖：六场景基础任务、多人隔离、金额守恒、规则版本、权限边界、注入攻击、幂等、并发、故障恢复、定时执行、完整交互流程。

> 测试规模为项目自定测试计划（沿用附件 PDF 建议的 120 条规模），**并非官方规定**。零失误只代表该测试集，不代表绝对安全。

关键验收用例断言（均通过）：

| 用例 | 断言结果 |
| --- | --- |
| P-07 分摊 150/110/70 | `test_acceptance_case_1_due` |

| 用例 | 断言结果 |
| --- | --- |
| P-08 规则变更 | `test_rule_change_generates_difference_drafts` |
| P-09 两笔 68 元 | `test_two_68_withdraw_duplicate` |
| P-10 越权拒绝 | `test_cannot_query_other_balance` 等 |
| P-11 部分完成 | `test_partial_completion_p11` |
| P-12 超时恢复 | `test_transfer_timeout_then_recover` |
| 日累计升级 | `test_daily_limit_upgrade_800_then_300` |

---

## 13. 部署与复现

见 `README.md`（安装、配置、启动、登录三个演示账号、复现关键流程）。

```
python -m venv .venv && source .venv/bin/activate   # Windows: .venv\Scripts\activate
pip install -r requirements.txt
python scripts/init_db.py --reset
python run.py                                       # 访问 http://127.0.0.1:8000
python -m pytest tests/ -q                          # 运行测试
```

真实模型模式：`.env` 设 `APP_MODE=llm` + `LLM_API_KEY`；离线模式无需 API Key。

---

## 14. 创新对照

| 维度 | 对照组（固定分摊 + 无证据卡） | 实验组（共识护航） |
| --- | --- | --- |
| 规则变更后错付 | 旧规则继续执行 | 旧授权失效、冻结未付款、补付/退款草稿 |
| 协调轮次 | 需人工反复对齐 | 版本化确认，只对受影响成员重新确认 |
| 异常识别 | 同额即判盗刷/重复 | 证据卡待核验，追问后撤回或处置 |
| 有效追问 | 无结构化证据 | 关联交易号/授权/时间/反馈 |

区分**系统处理时间**与**等待成员确认时间**（见测试报告；未测项标未测）。

---

## 15. 已知风险与模拟边界

- 模拟银行接口、模拟强验证是否符合主办方验收口径 → **待确认**。
- GitHub 仓库地址 → **待补**（未创建，不伪造链接）。
- 未接入真实银行/人脸/短信/U 盾；所有资金、产品、交易为合成数据。
- 模型只接收完成当前任务所必需的数据；离线模式不宣称真实模型接入。

## 16. 第三方依赖与许可证

FastAPI、SQLAlchemy、pydantic、uvicorn、httpx、pytest、python-dotenv、tzdata 等，均为开源软件，许可证清单见 `docs/第三方依赖与许可证.md`。项目整体采用 MIT 许可证。